

המשך שמפגש 7 - CKC

מטריצת הפעולה: הגנה רב-שכבתית

	Detect (זיהוי)	Deny (מניעה)	Disrupt (שיבוש)	Degrade (דיכוי)	Deceive (הטעיה)	Destroy (השמדה)
Reconnaissance (סיור)	✓					
Weaponization (התחמשות)						
Delivery (משלוח)	✓					
Exploitation (ניצול)		👤 × 🛡️				
Installation (התקנה)	✓					
C2 (פיקוד ושליטה)			👤 × 📡		🛡️ × 🐝	
Actions (פעולות ביעד)	✓	👤 × 🛡️				



Detect (זיהוי)
ניתוח וזיהוי
ניסיונות חדירה.

SIGNAL AMBOS



Deny (מניעה)
עצירת ההתקפה
בזמן אמת.

DEFENSE SLATE



Disrupt (שיבוש)
פגיעה בתקשורת
הנתונים של התוקף.

DEFENSE SLATE

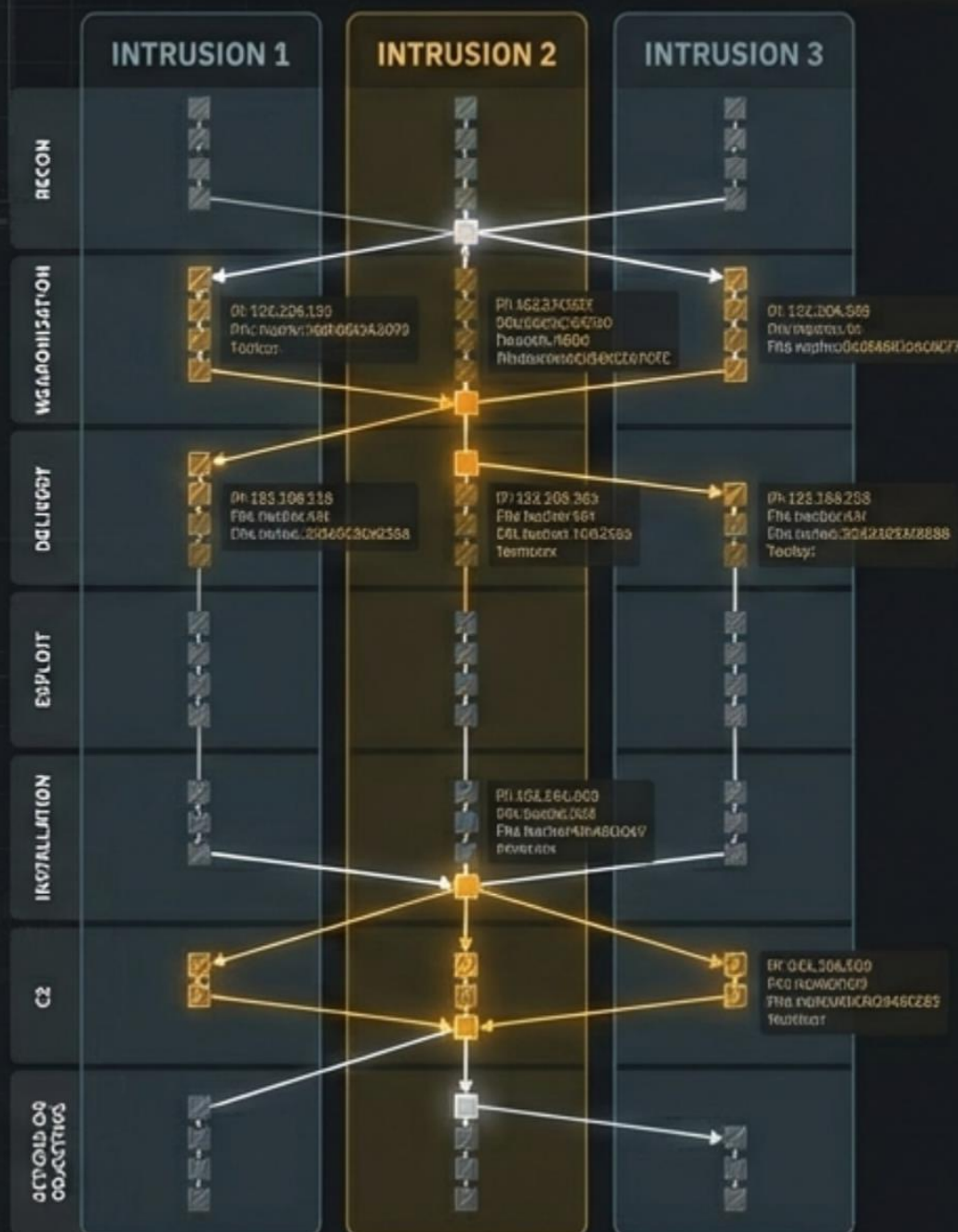


Deceive (הטעיה)
הובלת התוקף
למלכודות דבש.
(Honeypots)

DEFENSE SLATE

המטרה היא לייצר עומק הגנתי (Defense in Depth).

ניתוח קמפיינים: חיבור הנקודות (Campaign Analysis)



• **העיקרון:** אסור לנתח אירוע בודד במנותק. יש לחפש דפוסים חוזרים.

• **היתרון המודיעיני:** ההתמדה של התוקף הופכת לנקודת התורפה שלו.

• שימוש חוזר בתשתיות, כלי נשק או טכניקות (TTPs) מאפשר למגן לזהות את ה'קמפיין' ולחזות את הצעד הבא.

מסקנה:

זיהוי מכנה משותף אחד (למשל, כתובת IP של שרת C2) יכול לשרוף קמפיין שלם של התוקף.

אתגרים ומגבלות במודל המסורתי

Cloud / IoT Bypass

Perimeter Defense

Insider Threat

התמקדות בהיקף (Perimeter Focus):

המודל המקורי מניח שהתוקף מגיע מבחוץ.
פחות יעיל כנגד איומים פנימיים
(Insider Threats).



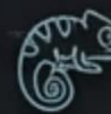
שינוי הנוף הטכנולוגי: המעבר לענן (Cloud)
ול-IoT משנה את גבולות הגזרה.



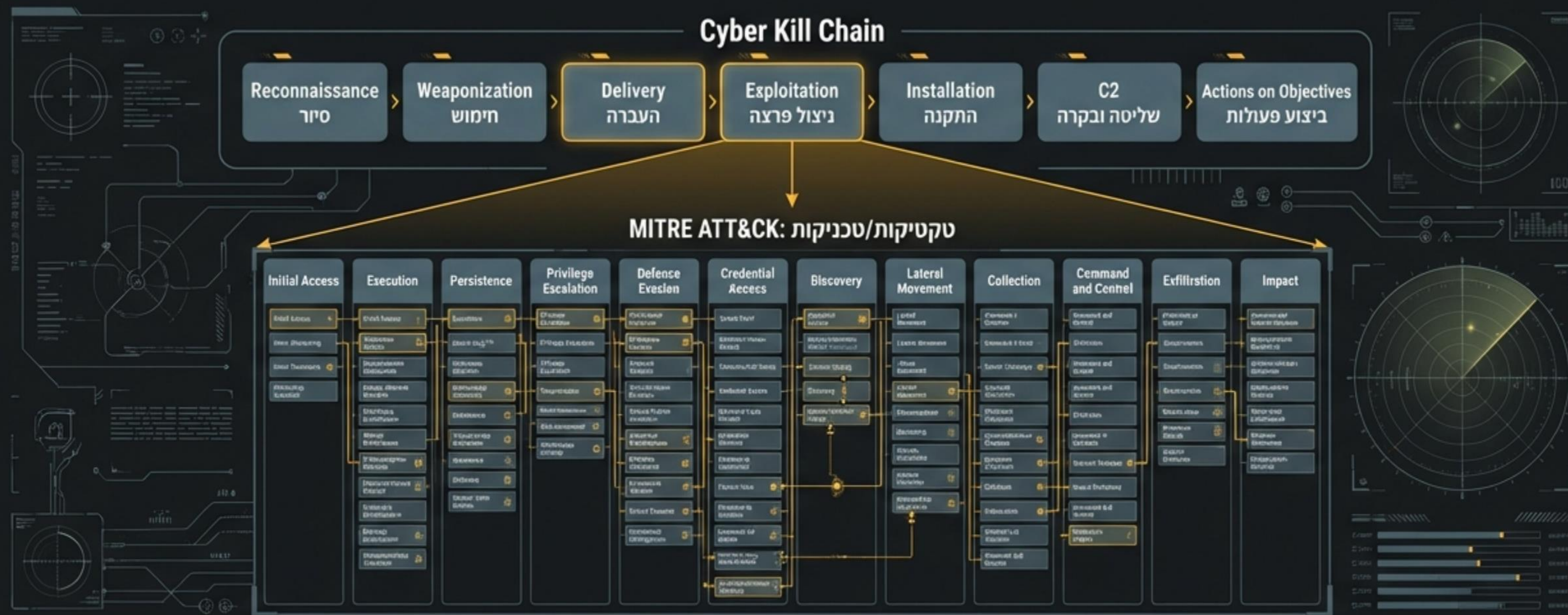
דילוג על שלבים: תוקפים מודרניים עשויים
לדלג על שלבים (למשל, באמצעות רכישת
גישה קיימת).



הסתגלות התוקף: עצם הכרת המודל מאפשרת
לתוקפים לשנות טקטיקה כדי להימנע גילוי.



השילוב המנצח: CKC & MITRE ATT&CK

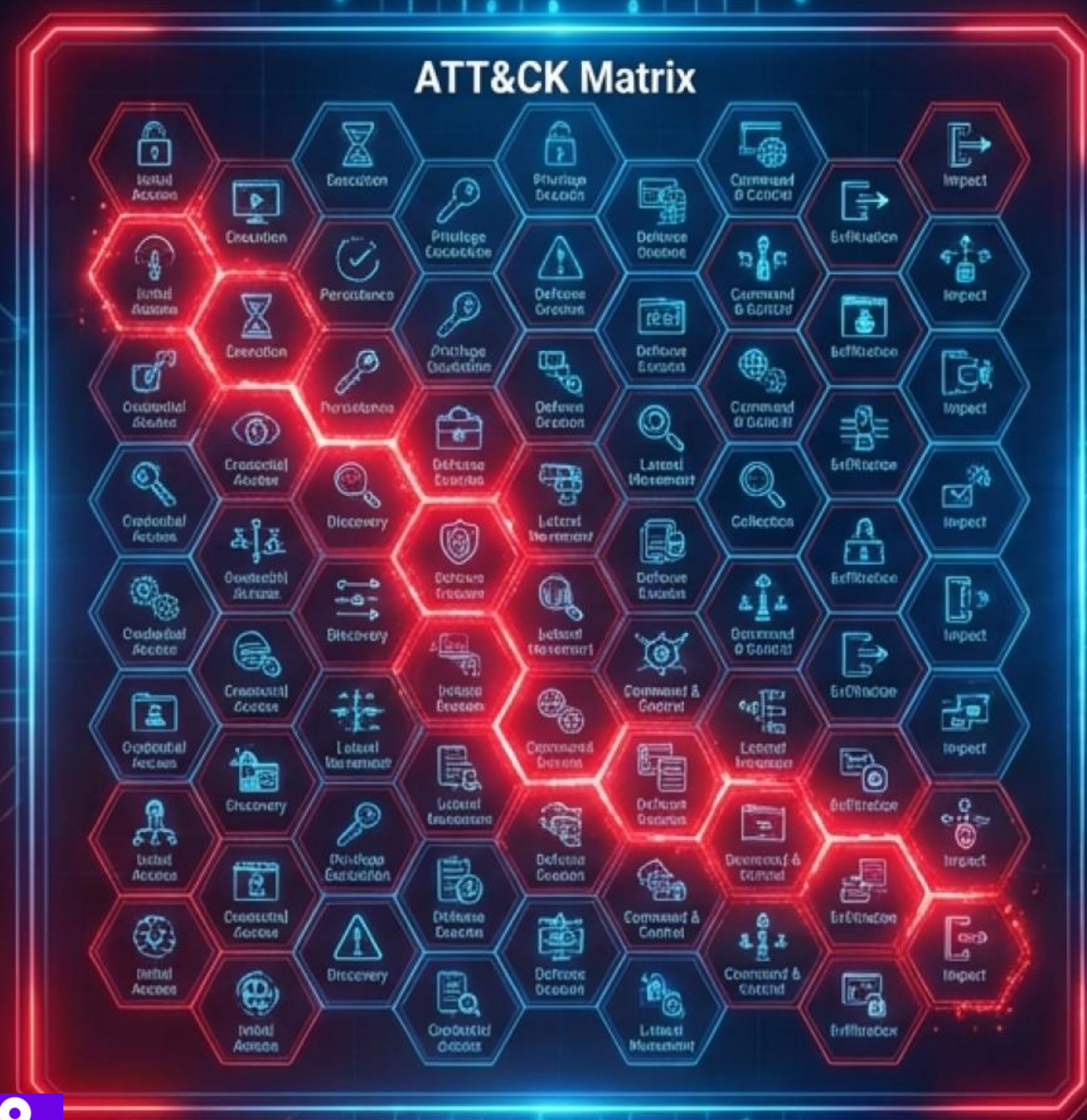


Cyber Kill Chain: מספקת את ההקשר האסטרטגי ("באיזה שלב של התקיפה אנחנו נמצאים?"). מצוינת לזיהוי מוקדם ומניעה.

MITRE ATT&CK: מספקת את המידע הטקטי המפורט ("איזו טכניקה ספציפית מופעלת?"). מצוינת מצוינת לציד אימים (Threat Hunting) ולניתוח לאחר חדירה.

הסינרגיה: שימוש ב-CKC כדי לבנות תרחישי Red Team, ושימוש ב-MITRE כדי לוודא כיסוי הגנתי מלא.

יישום 1: מודיעין איומים (Know Your Enemy)



פרופיל תוקף: שימוש ב-ATT&CK למיפוי קבוצות תקיפה רלוונטיות למגזר שלכם (למשל, קבוצת APT19 המכוונת למגזרים ספציפיים).

מיקוד ההגנה: אם ידוע שהתוקף משתמש בטכניקה ספציפית (למשל Registry Run Keys), ניתן למקד את ניטור ה-SOC לזיהוי חריגות באזור זה.

שיתוף מידע: סטנדרטיזציה של דוחות מודיעין מאפשרת שיתוף מהיר של IOCs ו-TTPs בין ארגונים.

יישום 2: ניתוח פערים בהגנה (Know Yourself)

מיפוי יכולות: הצלבת כלי ההגנה הקיימים (EDR, SIEM, FW) אל מול המטריצה.

זיהוי שטחים מתים: יצירת 'מפת חום' (Heat Map) – ירוק (מכוסה), צהוב (כיסוי חלקי), אדום (חשוף).

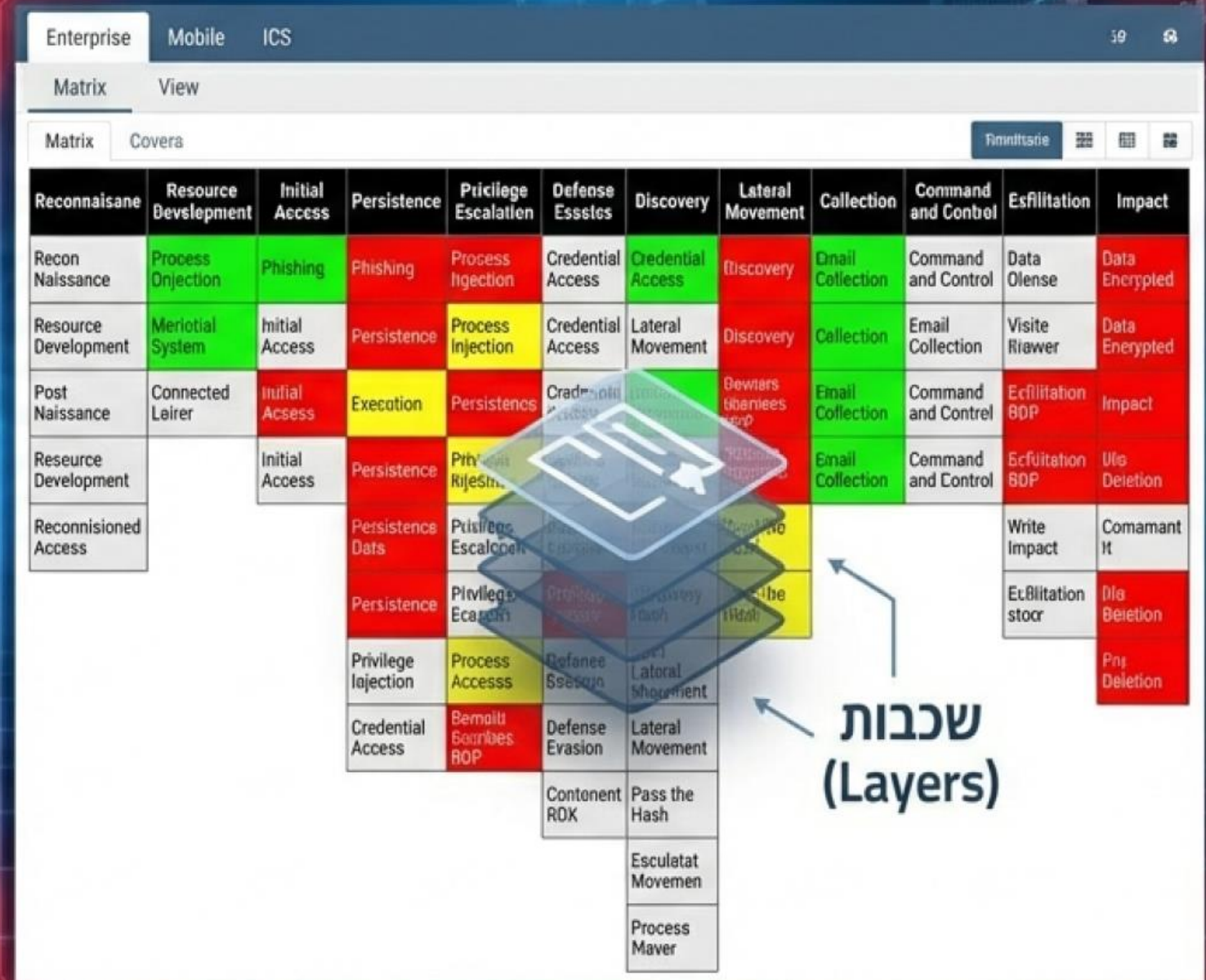
דוגמא: "אנחנו מצוינים בזיהוי Phishing (שלב הגישה), אך עיוורים לחלוטין ל-Lateral Movement באמצעות RDP."

Reconnaissance	Resource Development	Initial Access	Persistence	Privilege Escalation	Defense Evasion	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Reconnaissance	Process Injection	Phishing	Phishing	Process Injection	Credential Access	Credential Access	Discovery	Email Collection	Command and Control	Data Obfuscation	Data Encrypted
Resource Development	Internal System	Initial Access	Persistence	Process Injection	Credential Access	Lateral Movement	Discovery	Collection	Email Collection	Website Tampering	Data Encrypted
Post Reconnaissance	Connected Mailer	Initial Access	Execution	Persistence	Credential Access	Lateral Movement	Remote Services: RDP	Email Collection	Command and Control	Exfiltration RDP	Impact
Resource Development		Initial Access	Persistence	Process Injection	Defense Evasion	Plaintext Hash	Remote Services: RDP	Email Collection	Command and Control	Exfiltration RDP	File Deletion
Reconnaissance Access			Persistence Data	Privilege Escalation	Defense Evasion	Lateral Movement	Pass the Hash			Write Impact	Compromised It
			Persistence	Privilege Escalation	Defense Access	Discovery Hash	Pass the Hash			Exfiltration Storage	File Deletion
			Privilege Injection	Process Injection	Defense Evasion	Start Lateral Movement					File Deletion
			Credential Access	Remote Services: RDP	Defense Evasion	Lateral Movement					
					Controlnet Disk	Pass the Hash					
						Escalate Privileges					
						Process Player					

(Covered) ■ (Partial) ■ (Vulnerable) ■ כיסוי חלקי

הכלי המרכזי: MITRE ATT&CK Navigator

- כלי קוד פתוח המאפשר ויזואליזציה של המטריצה.
- שימוש בשכבות (Layers): היכולת להניח שכבות מידע זו על גבי זו. למשל: שכבה המייצגת את תוקף א, מול שכבה המייצגת את יכולות ההגנה של הארגון.
- התאמה אישית: יצירת מטריצות מותאמות לאיומים ספציפיים (למשל Ransomware או טכנולוגיות ספציפיות Cloud vs. On-Prem).



The screenshot shows the MITRE ATT&CK Navigator interface. The top navigation bar includes 'Enterprise', 'Mobile', and 'ICS'. Below it, there are tabs for 'Matrix' and 'View'. The main area displays a matrix of attack techniques, with columns representing different stages of an attack and rows representing specific techniques. A blue cube with arrows is overlaid on the matrix, and a label 'שכבות (Layers)' points to it.

Reconnaissance	Resource Development	Initial Access	Persistence	Privilege Escalation	Defense Evasion	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Reconnaissance	Process Injection	Phishing	Phishing	Process Injection	Credential Access	Credential Access	Discovery	Email Collection	Command and Control	Data Breach	Data Encrypted
Resource Development	Malicious System	Initial Access	Persistence	Process Injection	Credential Access	Lateral Movement	Discovery	Collection	Email Collection	Website Hijack	Data Encrypted
Post Reconnaissance	Connected Lateral	Initial Access	Execution	Persistence	Credential Access	Discovery	Discovery	Email Collection	Command and Control	Exfiltration BOP	Impact
Resource Development		Initial Access	Persistence	Privilege Escalation	Privilege Escalation	Discovery	Discovery	Email Collection	Command and Control	Exfiltration BOP	Use Deletion
Reconnaissance			Persistence	Privilege Escalation	Privilege Escalation	Discovery	Discovery			Write Impact	Command and Control
			Persistence	Privilege Escalation	Privilege Escalation	Discovery	Discovery			Exfiltration BOP	Use Deletion
			Privilege Injection	Process Access	Defense Evasion	Lateral Movement	Lateral Movement				Use Deletion
			Credential Access	Remote Services ROP	Defense Evasion	Lateral Movement	Lateral Movement				Use Deletion
					Content ROP	Pass the Hash					
						Escalate Movement					
						Process Mover					

מתקדם: סימולציה ואמולציית יריב (Red Teaming)

Red Team
(תוקף)

Red Team
(תוקף)

Blue Team
(מגן)

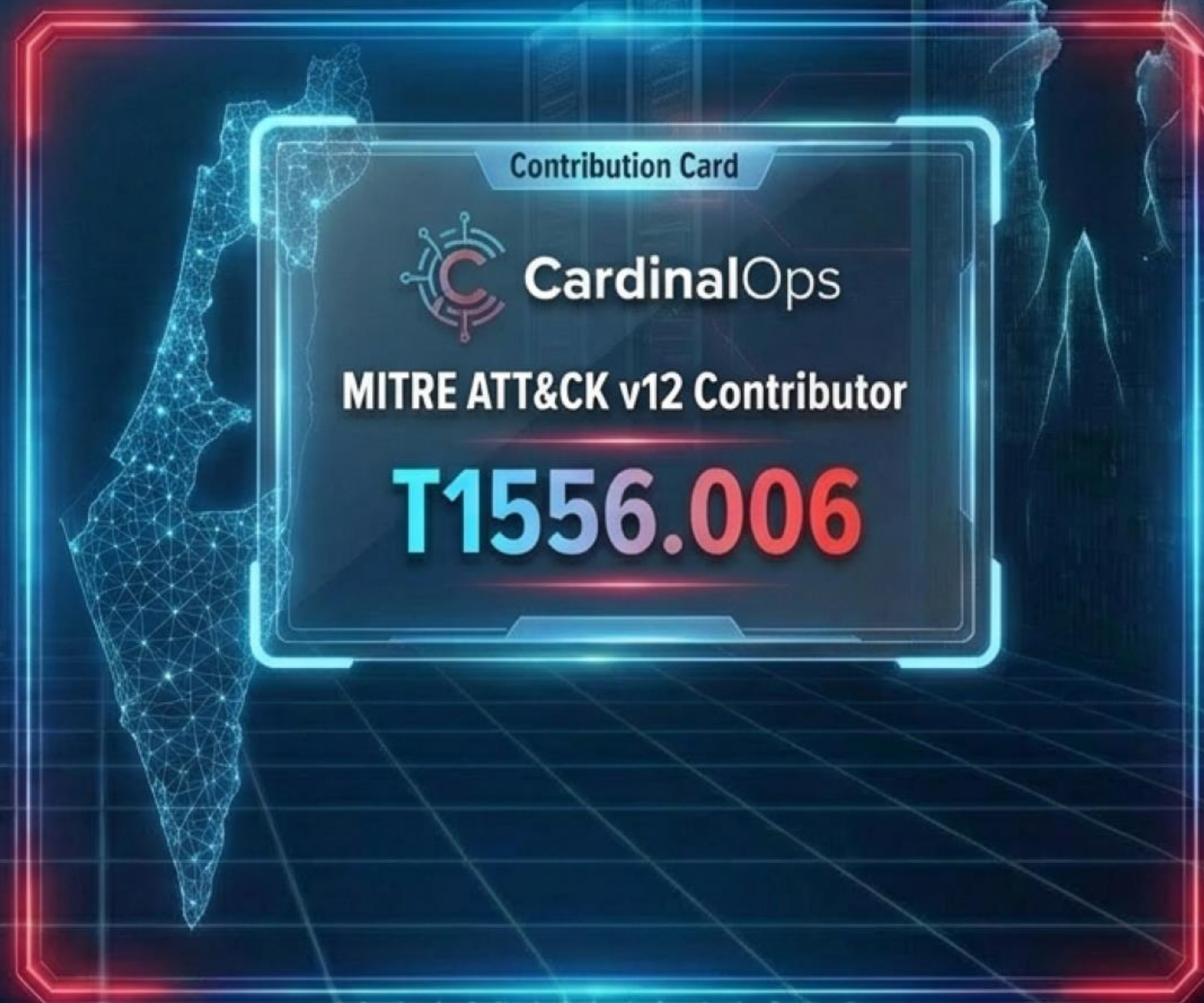
במקום מבדקי חדירה: **Test Like You Fight**
מבדקי חדירה (Pentest) אקראיים,
שימוש במתווה מדויק של תוקף מוכר
(Adversary Emulation).

בניית תרחיש: יצירת תסריט תקיפה
המבוסס על רצף TTPs אמיתי.

שימוש Atomic Red Team:
בספריות בדיקה פתוחות לבדיקת
לבדיקת בקורות הגנה ספציפיות
(למשל: 'האם המערכת מזהה
הרצת Mimikatz?').

הזווית הישראלית: תרומה למאגר הידע העולמי

- המודל הוא קהילתי ומתעדכן תדיר על ידי חוקרים.
- תרומה ישראלית (CardinalOps): צוות המחקר של חברת CardinalOps (יאיר מנור ומיכאל מומצ"וגלו) תרם לגרסה v12 של המודל.
- הטכניקה החדשה: זיהוי ותיעוד טכניקה לעקיפת (MFA Bypass) - ממופה כ- T1556.006.
- המשמעות: רלוונטיות קריטית ליישום מודל Zero Trust בסביבות Azure AD ו-Office 365.



סיכום: למה לאמץ את MITRE ATT&CK?

שפה משותפת: סטנדרטיזציה של התקשורת בין צוותי מודיעין, SOC, והנהלה.

הגנה מונחית איומים: מעבר מהגנה 'על הכל' להגנה ממוקדת על הפרצות הסבירות ביותר.

מדידה אובייקטיבית: היכולת לכמת את רמת ההגנה ולזהות פערים בצורה ויזואלית.

קהילה חיה: בסיס ידע שמתעדכן בזמן אמת עם התפתחות איומי הסייבר (כדוגמת התרומה הישראלית).



מקורות וכלים להעמקה



MITRE ATT&CK Official Site

attack.mitre.org -
המאגר המלא.



ATT&CK Navigator

הכלי ליצירת מפות חום
ושכבות הגנה.



Atomic Red Team

ספריית בדיקות לאמולציית
איומים.



See Security

קורסים והכשרות מתקדמות
למקצועות ה-SOC
וה-CISO.

תודה רבה.



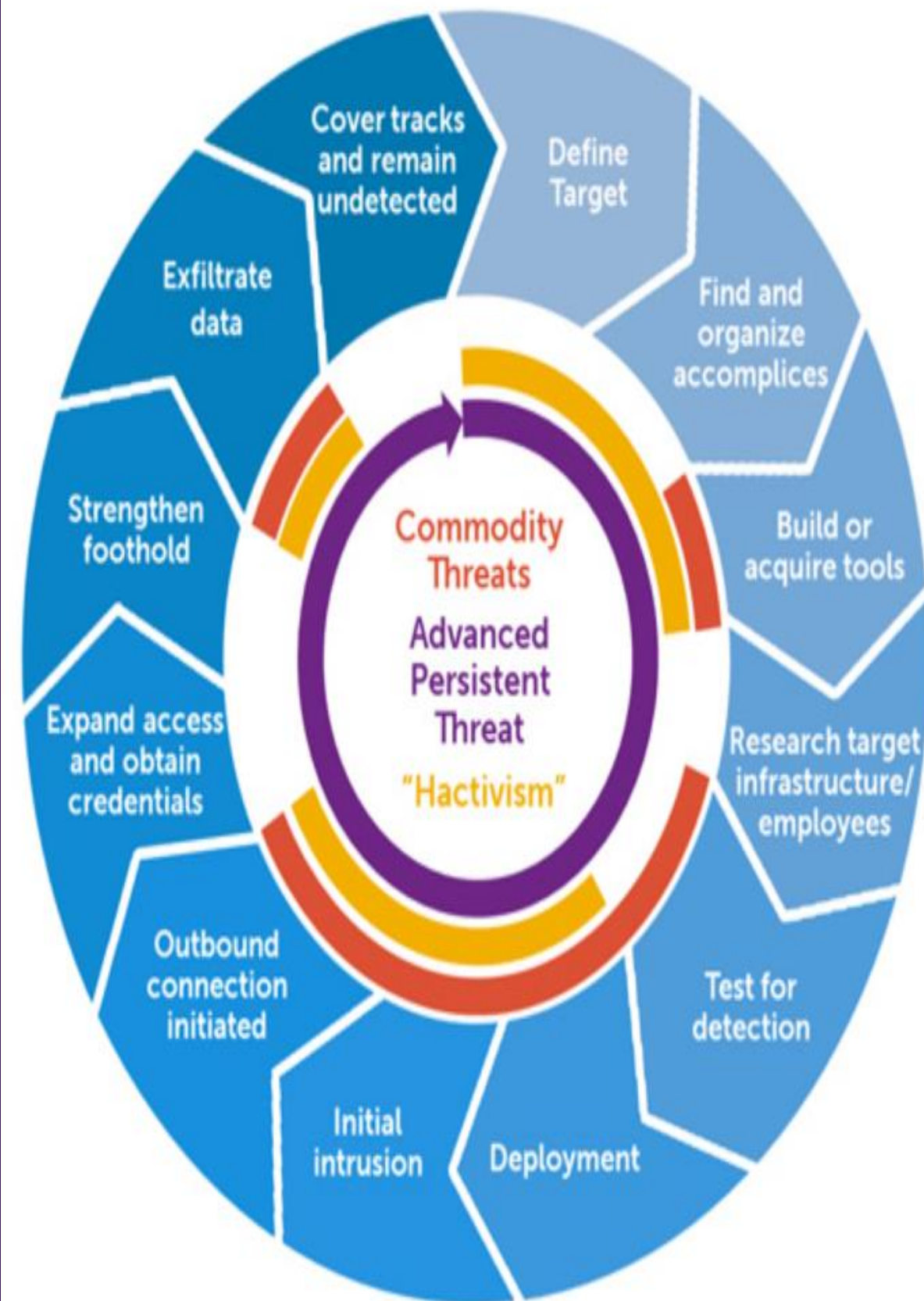
שרשת ההספקה..

שרשרת ההספקה.... החוליה החלשה



APT

תקיפת סייבר, שהגורם המבצע אותה מפעיל מאמץ מתמשך לשם מימושה. אופייני שבמתקפה מתמשכת ישתמש התוקף בשיטות ואמצעים טכנולוגיים מתקדמים.

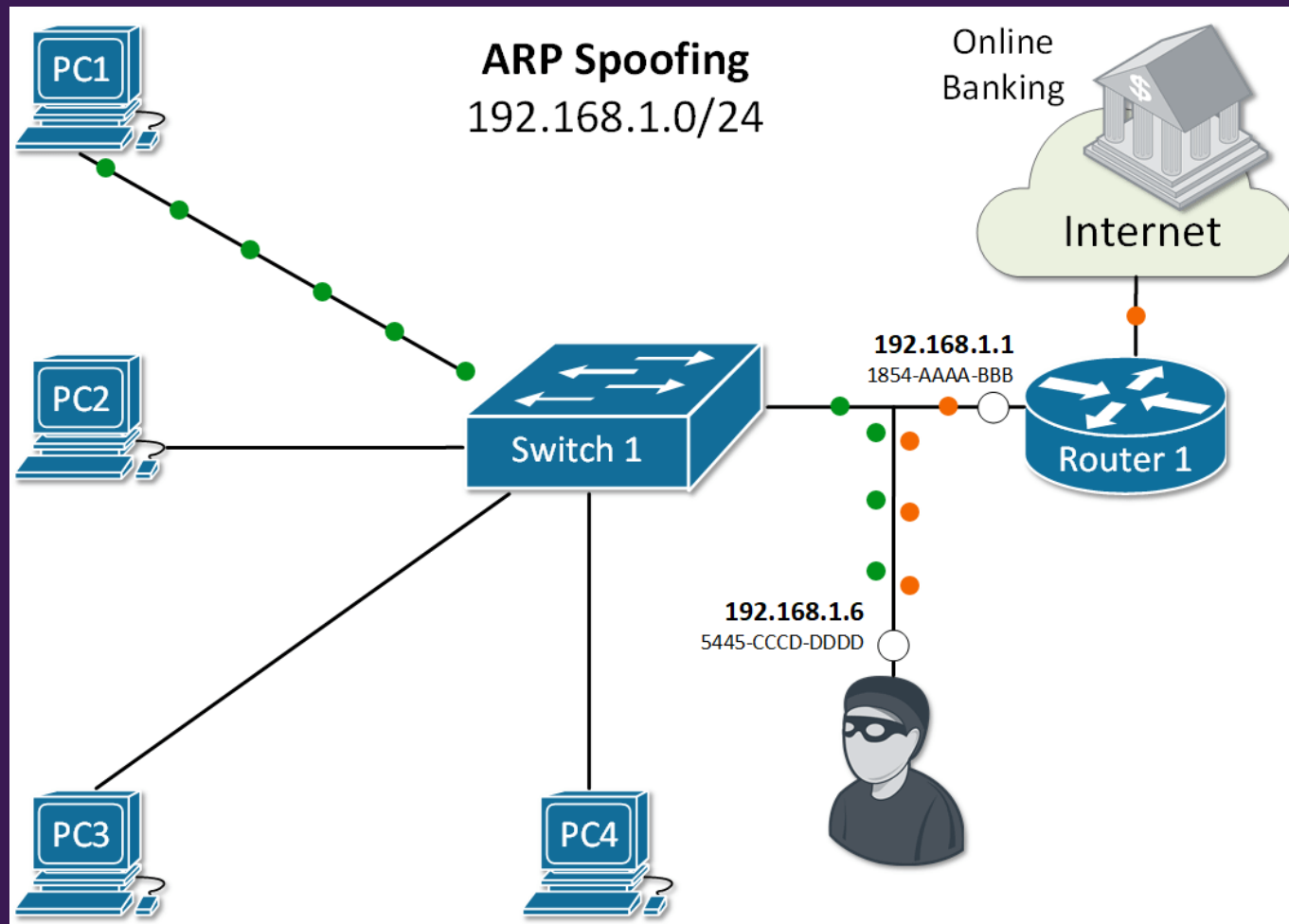


התקפות "ריסוס" ו/או התקפות בעלות רמת מורכבות בינונית/נמוכה

- הפצת מייל FISHING לכתובות רבות
 - ניצול שימוש בפרוטוקולים לא בטוחים (ARP, Telnet, FTP, HTTP, and SMTP)
 - ניצול שימוש בסיסמאות ברירת מחדל – למשל PASSWORD
 - ניצול חולשות ידועות בתכנה
 - ניצול עבודה עם ציוד מחשוב בתצורה לא בטוחה/מוקשחת – למשל חיבורי כבלים לא נחוצים
 - Misconfigurations - פרצות במוצר
- התקפות אלו מתבצעות לא פעם על ידי גורמים שונים כגון האקטיביסטים, גופי פשיעה, האקרים בודדים, מתחרים עסקיים (כן כן) ועוד...



למשל ARP – Address Resolution Protocol



- הפרוטוקול בהגדרה לא מאובטח (1982)
- לא בודק חבילות ARP
- ויכול לקבל חבילה גם היא לא נשלחה במקור
- ARP SPOOFING
- כשגורם עוין מתחבר לרשת (לפעמים חיבור פיזי מיחידה שלא בשימוש או נקודת רשת) ושולח פקודות, ARP הנתב ופרוטוקול ARP יחבר אותו לרשת ויתן לו כתובת IP של אחד המחשבים ברשת. ואז...
- Man in the middle – הפורץ לוקח חבילות ARP ומשנה את יעדן או עונה תשובות שגויות חזרה
- Session Hijacking – לנסות לגנוב cookie, token, session ID - לגשת למידע פרטי
- DOS – לשלוח מידע כוזב בכמויות ולהציף את הרשת

מבפנים

איומי סייבר מרכזיים בשרשרת האספקה

1 גישה בלתי מורשית

ספקים עלולים להוות נקודות חולשה במערכת אם אין בקרת גישה ובקרה מספקות.

2 מתקפות סייבר על ספקים

האקרים מנצלים חולשות של צדדים שלישיים כדי לחדור לרשת הארגון

3 פגיעה בתוכנה או בחומרה

התקפות מבוססות קוד זדוני או "דלתות אחוריות" במוצרים המסופקים – הכי משתלם

4 דליפת מידע רגיש

נתוני לקוחות, ספקים ומידע עסקי רגיש עלולים לדלוף דרך חולשות אבטחה

5 חולשה של ספקי משנה

ספקים שאינם מקפידים על אמצעי אבטחה מספקים מהווים סיכון לכל שרשרת האספקה

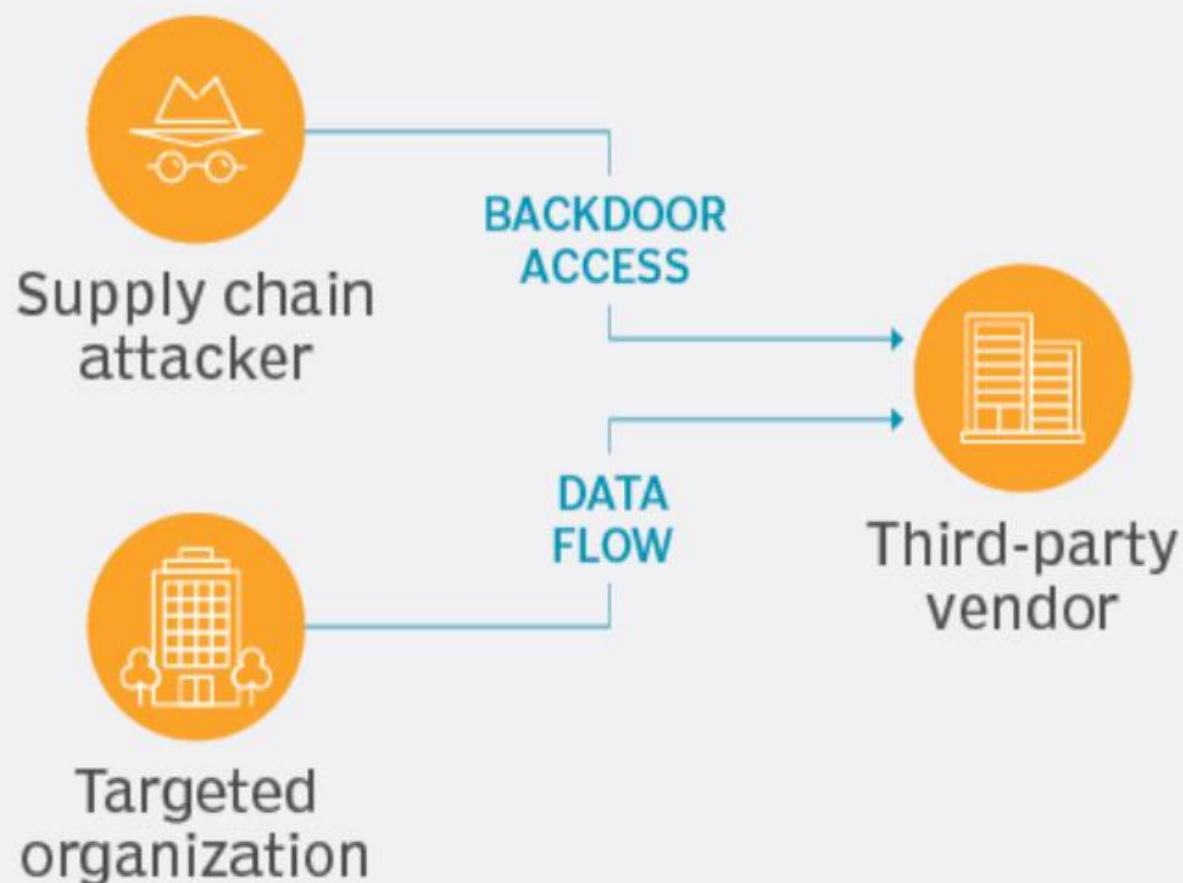
6 התקפות מניעת שירות

שיבוש ע"י DDOS

7 זיוף או פגיעה במוצרים

שינוי במוצרים במהלך הייצור או האספקה עלול לגרום לנזק משמעותי

Supply chain attack



התפתחות האיום: מפגיעה ישירה לחתירה תחת ערוצי אמון

Threat Evolution Matrix

מתקפות מסורתיות

וקטור תקיפה	ניצול חולשות תוכנה (Exploitation)	
מטרה עיקרית	הארגון עצמו	
זמן שהייה (Dwell Time)	ימים עד שבועות	
רמת אמון מנוצלת	נמוכה (חיבורים חיצוניים)	

שרשרת אספקה (Cascading)

שימוש בתוכנות וכלים לגיטימיים של צד ג'	
ספקים, מפתחים, ותשתיות בנייה (Build environments)	
חודשים עד שנים, בחסות תהליכים מורשים	
מוחלטת (חתימות דיגיטליות, עדכונים אוטומטיים)	

פתרונות מרכזיים

1

מדיניות ניהול סיכונים
ניתוח ואבחון חולשות אבטחה בקרב כל הספקים.

2

בקרת גישה קפדנית
שימוש ב ZERO TRUST ובדיקת גישה מבוססת הרשאות מינימליות

3

הצפנת מידע ותקשורת
שימוש בפרוטוקולי הצפנה מתקדמים להבטחת העברת נתונים מאובטחת

4

ניטור שוטף
שימוש במערכות SIEM (Security Information and Event Management) לאיתור איומים בזמן אמת.

פתרונות מרכזיים - המשך

5

אבטחת קוד ותוכנה
ביצוע בדיקות אבטחה קפדניות על תוכנות וציוד שמגיעים מהספקים, כולל PT.

6

חוזים מחייבים בנושא אבטחה
דרישת עמידה בתקני אבטחה כמו ISO 27001 או NIST מספקים.

7

הגנה על שרשרת האספקה הפיזית
מניעת גישה בלתי מורשית למתקני הייצור והאספקה.

8

תכניות גיבוי והתאוששות
הבטחת המשכיות עסקית במקרה של מתקפה על שרשרת האספקה.

מסקנה: ארגונים חייבים לשלב אבטחת מידע כחלק בלתי נפרד מהניהול של שרשרת האספקה שלהם גם ברמה טקטית וגם אסטרטגית, תוך ניטור שוטף והבטחת עמידת הספקים בסטנדרטים מחמירים.

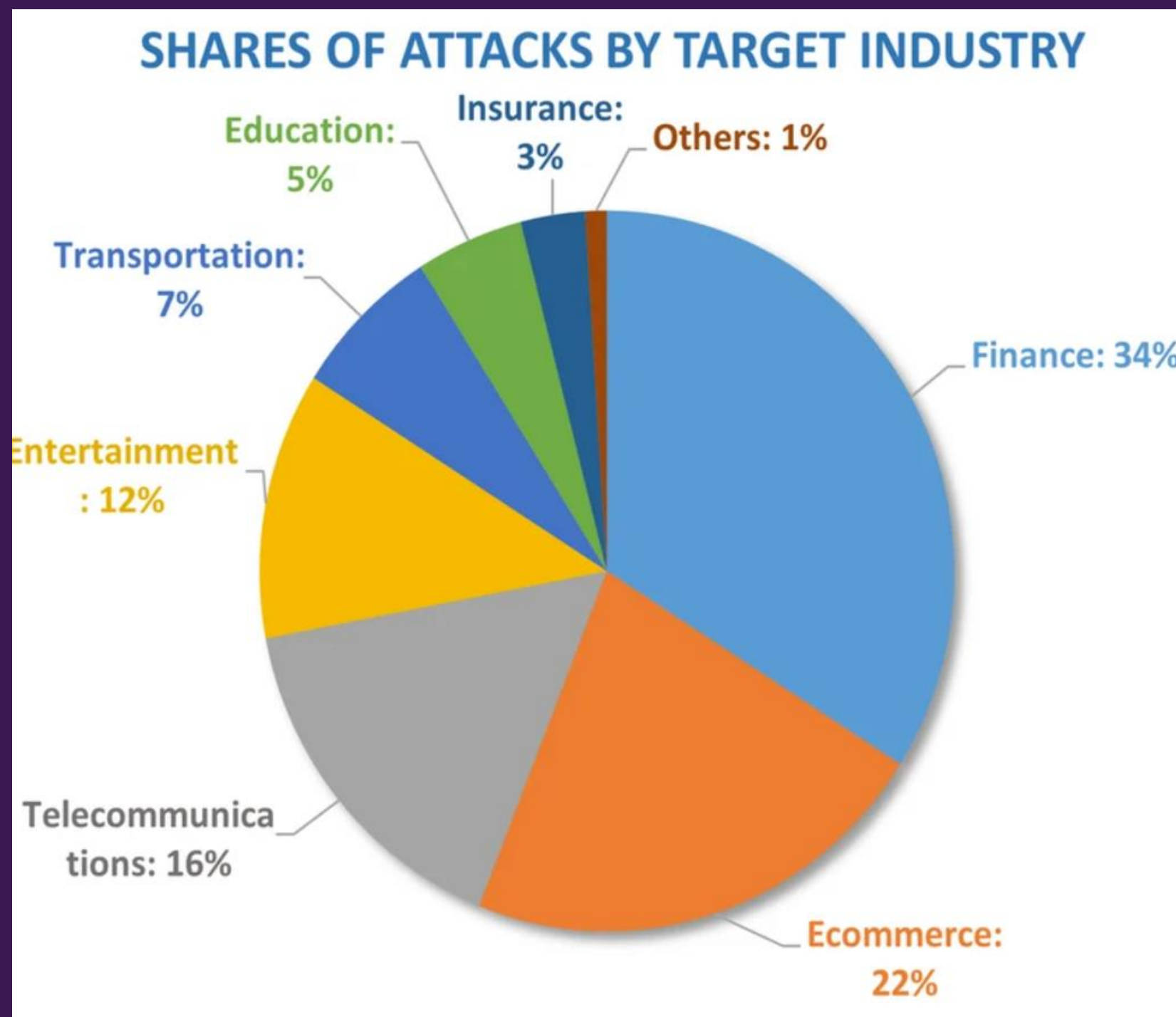


הדברים נראים שונה מקרוב

Meet Ryan Montgomery

https://www.youtube.com/shorts/ep1c_8fOEhg

התפלגות התקפות סייבר - 2025



מקרה בוחן: הפריצה הכפולה של 3CX (קמפיין C0057)

1. נקודת החדירה הראשונית

עובד 3CX הוריד גרסת תוכנה נגועה של חברת Trading Technologies שפג תוקפה.



2. ההשתלטות (UNC4736 / AppleJeus)

ניצול הגישה לחדור לסביבות הפיתוח והבנייה של 3CX (Build Environments).



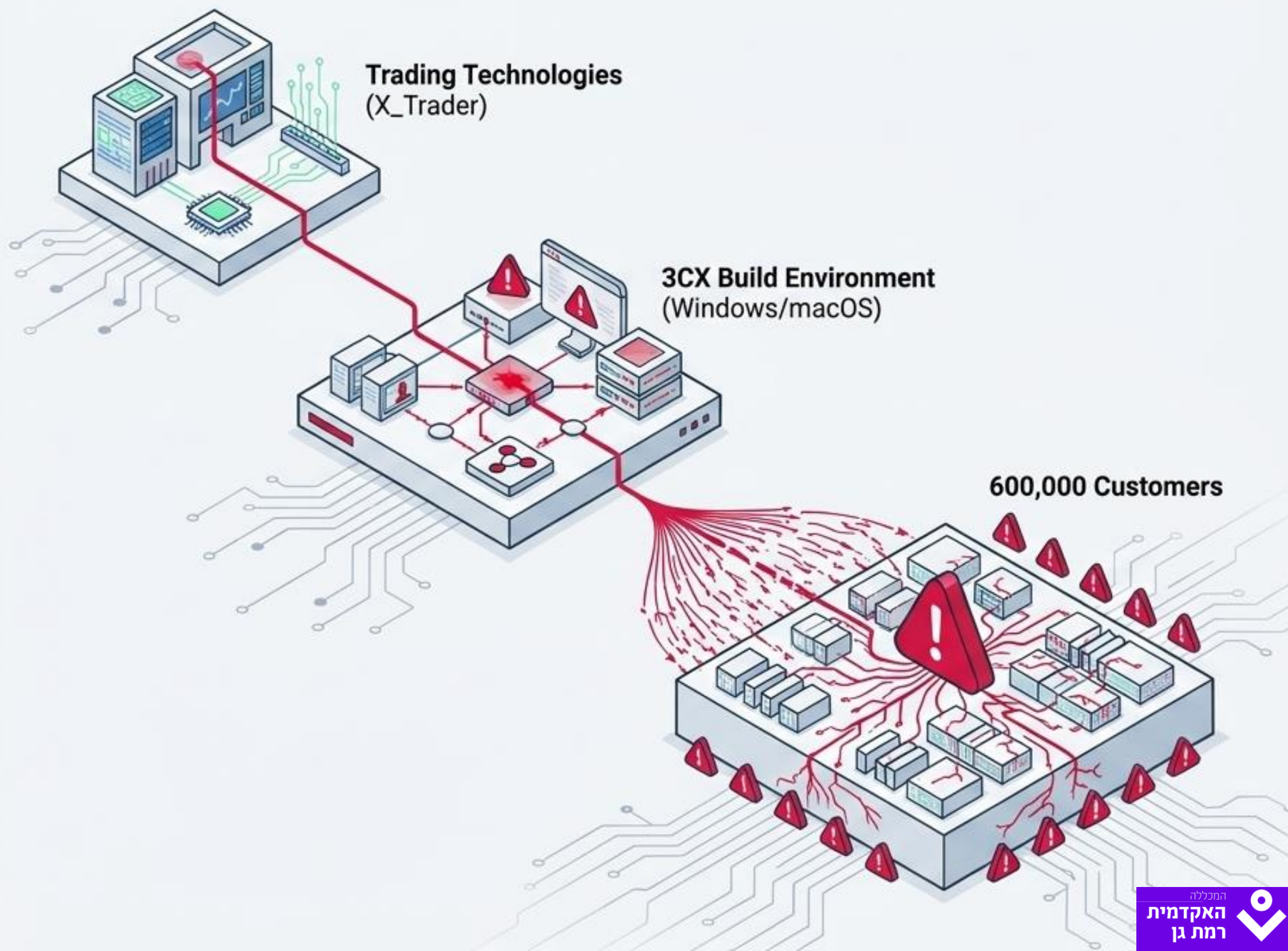
3. ההפצה ההמונית

תוכנת 3CX הלגיטימית הורעלה ונחתמה דיגיטלית, והופצה אוטומטית ללקוחות.



4. הנזק הסופי

הטמעת תוכנות דדוניות משניות (Gopuram) לגניבת אישורים ודריסת רגל עמוקה.



הנדסת חבלה: עקיפת בקורות אמון (T1553.002)

The Trojan Matryoshka

אריזה לגיטימית

שימוש בחבילת התקנה (MSI)
חתומה דיגיטלית של 3CX כמסווה.

.msi Package (Signed)

3CXDesktopApp.exe

ffmpeg.dll

חטיפת סדר טעינה (DLL Hijacking)

קובץ ההתקנה חילץ והריץ את
3CXDesktopApp.exe
שבתורו טען ספרייה זדונית בשם
ffmpeg.dll

הצפנה והסוואה

קוד ה-C2 (כגון VEILED SIGNAL)
הוצפן ב-RC4 מותאם אישית כדי
לחמוק מזיהוי מבוסס-חתימות.
הקוד העוין רץ תחת הרשאות של
אפליקציה מאושרת.

Q & A